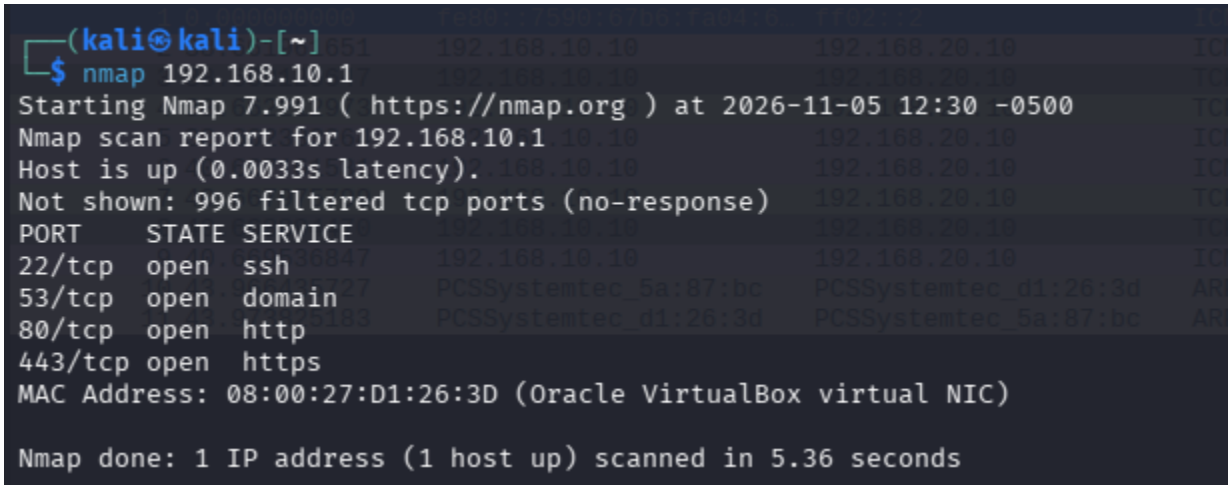
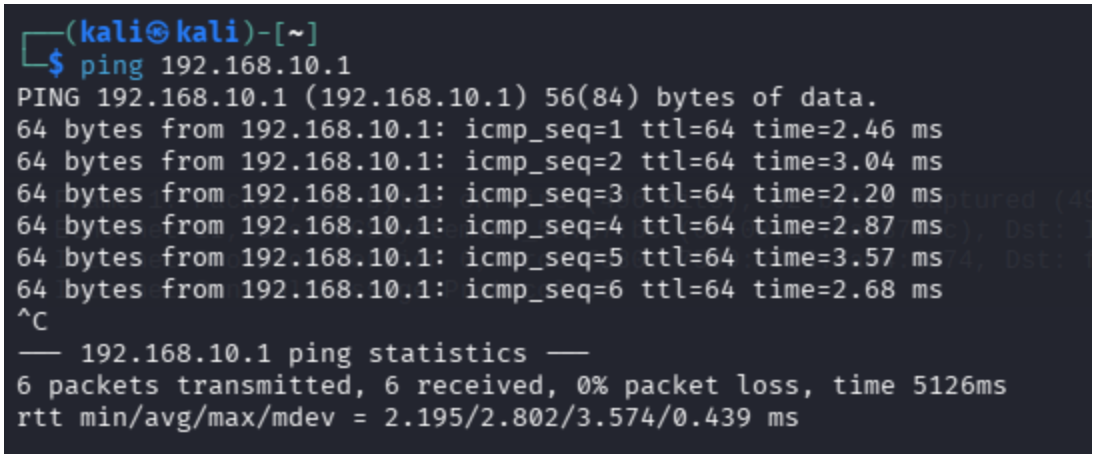
Home Lab Project Week 11, Day 2
Task:
Re-test selected exploitation attempts against the Metasploitable system and determine whether the new firewall rules prevent or limit the previously successful activity.

Phase 1: Pre-Test Setup & Verification

Before launching attacks, ensure your environment is correctly configured so you don't get false positives.

- **Confirm Firewall State:** Verify that your firewall (OPNsense, iptables) has the new rules actively applied to the interface facing the Ubuntu VM.
- **Verify Connectivity:** Ensure your attacker machine (Kali Linux) can still reach allowed services (if any) to confirm the firewall isn't simply down or completely blocking unintended traffic.
- **Clear Logs:** Clear or note the timestamps on your firewall logs so you can easily spot new blocks.





Phase 2: Execution & Comparative Testing

Run the exact same exploits or scans you used in previous weeks. Use this table to structure your testing and document the results.

Target Service / Vulnerability	Previous Result (Baseline)	Testing Command / Exploit Used	New Result (Rules Active)	Firewall Log Status
Example: FTP (Port 21) Exploit	*Successful root shell via vsftpd 2.3.4 backdoor*	`msfconsole -q -x "use exploit/unix/ftp/vsftpd_234_backdoor; set RHOSTS <IP>; exploit"`	**Exploit timed out / Connection refused**	*TCP Reset / DROP logged on Port 21*
Nmap TCP Port Scan	*All 20+ ports open and visible*	`nmap -sS -Pn -F <Metasploitable_IP>`		
SSH Brute Force (Port 22)	*Succeeded / Allowed password guessing*	`hydra -L users.txt -P pass.txt <IP> ssh`		

HTTP Web App Exploits (Port 80)	*Command injection / Webshell uploaded*	*(Specific curl command or Metasploit module)*
Samba (Port 139/445)	*RCE achieved via usermap_script*	`use exploit/multi/samba/usermap_script`

Phase 3: Analyzing the "Why"

For each test, categorize the firewall's behavior into one of three results:

- **Complete Prevention:** The attack completely fails because the firewall drops the packets (`DROP`/`DENY`). Nmap will likely show the port as `filtered`.
- **Rate/Traffic Limiting:** The exploit works initially but fails or slows down dramatically after a few attempts (indicates successful implementation of rate-limiting or IPS/IDS rules).
- **Bypass / Partial Success:** The exploit still works. This means the firewall rule is either too permissive, applied to the wrong interface, or the exploit is using a port/protocol that you explicitly left open (e.g., attacking a web app on Port 80 when only ports 21/22 were blocked).

Phase 4: Firewall Log Verification

An exploit failing on the attacker side is only half the battle. You must prove the **firewall** was the entity that stopped it.

1. Open your firewall's web GUI or CLI log viewer (e.g., `/var/log/filter.log` on pfSense).
2. Filter by the **Attacker IP** and **Metasploitable IP**.
3. Look for the corresponding `BLOCK` or `REJECT` actions matching the timestamps of your test window.
4. Take screenshots of these logs for your final project documentation.

To help tailor the next steps of your lab report, let me know:

- What **specific exploits** (like vsftpd, Samba, or SSH brute forcing) are you re-testing today?
- What **firewall solution** (pfSense, iptables, etc.) are you using?
- Did any attacks **successfully bypass** your new rules?